

Enterprise IAM Project

Hybrid Identity, Lifecycle Automation, Governance, and Identity Threat Detection

Hussein Al-Hebshi

1. Overview

I built this project to cover the full life of an identity in a hybrid enterprise. The identity starts in Active Directory, syncs to the cloud, gets its access through automation, gets reviewed and governed, gets attacked and defended, and finally gets removed when the person leaves. Every part builds on the one before it.

Everything here was built hands-on in my own environment except where a paid platform like CyberArk was needed. In those cases I covered the concept instead of pretending I deployed it.

The project covers six areas:

- Hybrid identity foundation with AD and Entra Connect
- Identity lifecycle automation (joiner, mover, leaver)
- Access governance with PIM, access packages, access reviews, and SoD
- Zero Trust authentication with Conditional Access and passwordless
- Identity threat detection and response with MDI, Identity Protection, and Sentinel
- Enterprise IGA concepts with SailPoint and workload identity

2. My Environment

Component	What I used
Identity source	simbaloa.local Active Directory on Windows Server 2022
Sync engine	Entra Connect with Password Hash Sync
Cloud directory	Entra ID P2 (M365 E5 tenant)
Endpoint	Hybrid-joined Windows 11 device managed by Intune
ITDR	Microsoft Defender for Identity sensor on the domain controller
SIEM and SOAR	Microsoft Sentinel with Azure Logic Apps
IGA	SailPoint Identity Security Cloud (conceptual — free developer tenant no longer available without partner status)
CI/CD identity	GitHub Actions with workload identity federation

3. Hybrid Identity Foundation

In a hybrid setup the identity is not born in the cloud. HR creates it, it lands in Active Directory, and Entra Connect projects it to Entra ID. AD owns most attributes and the cloud owns a few cloud-only ones. Knowing which side owns which attribute matters, because if you edit a synced attribute in the portal, the next sync cycle overwrites it and your change silently disappears.

Why I chose Password Hash Sync

I went with PHS over PTA and Federation for three reasons. Sign-in keeps working even if the on-prem side is down. PHS feeds the leaked credential detection in Entra ID Protection, which PTA cannot do because the hashes never reach the cloud. And Federation with AD FS adds a big attack surface that Microsoft is moving away from anyway.

The attribute mapping problem

The lifecycle workflows in the next section trigger on `employeeHireDate` and `employeeLeaveDateTime`. These two attributes are cloud-only. You cannot write them directly on a synced user from the portal or Graph. The only supported way is to store the value in an AD attribute and map it through Entra Connect.

This took real troubleshooting. My first attempts with `extensionAttribute1` failed because my AD schema had no Exchange extensions. Other candidate attributes failed for their own reasons. What finally worked was `msDS-cloudExtensionAttribute1` and 2, which exist in the default Server 2022 schema.

The date format was the second trap. The AD value must be in Generalized-Time format or the sync fails with an invalid date error:

```
Set-ADUser joiner.test -Replace @{ 'msDS-cloudExtensionAttribute1'='20260601080000.0Z' }
```

Then I cloned the In from AD - User Common rule in the Synchronization Rules Editor, set precedence 150, and added two Direct flow transformations mapping the AD attributes to `employeeHireDate` and `employeeLeaveDateTime`. Direct flow works because the AD value is already in the exact format the target expects. Conversion expressions are the most common failure here and they are not needed when the source format is right.

Synchronization Rules Editor showing the cloned inbound rule with two Direct flow transformations

The screenshot shows the Synchronization Rules Editor interface. The main window displays a list of synchronization rules, with the selected rule being "In from AD - User Common - Cloned - 5/28/2026 6:56:00". The rule is cloned from "In from AD - User Common". The rule details show it is a "Join" rule with "Transformations: Disabled" and "Join: 59".

The "View inbound synchronization rule" dialog is open, showing the "Add transformations" tab. The dialog lists the following transformations:

FlowType	Target Attribute	Source	Apply Or	Merge Type
Expression	streetAddress	Trim([streetAddress])	☐	Update
Expression	telephoneNumber	Trim([telephoneNumber])	☐	Update
Direct	thumbnailPhoto	thumbnailPhoto	☐	Update
Expression	title	Trim([title])	☐	Update
Expression	userPrincipalName	IF([isPresent([userPrincipalName])], [	☐	Update
Expression	url	IF([isEmpty([url]), NULL, Left(T	☐	Update
Expression	wwwHomePage	Trim([wwwHomePage])	☐	Update
Direct	employeeHireDate	msDS-cloudExtensionAttribute1	☐	Update
Direct	employeeLeaveDateTime	msDS-cloudExtensionAttribute2	☐	Update

EmployeeHireDate populated on the synced user

The screenshot shows the Azure AD user profile for "Joiner Test". The user's "Employee hire date" is populated as "May 29, 2026, 4:00 a.m.". The user's "Job title" is "Security Analyst".

The user's profile details are as follows:

Property	Value
User principal name	joiner.test@simbaloa.onmicrosoft.com
Object ID	2506405c-b4dd-4515-acb0-316c118e6ebb
Identities	Simbaloa.onmicrosoft.com
User type	Member
Creation type	
Created date time	May 27, 2026, 5:10 p.m.
Assigned licenses	View
Preferred language	
Sign in sessions valid from date ...	May 27, 2026, 5:08 p.m.
Last password change date time	May 27, 2026, 5:08 p.m.
Invitation state	
External user state change date t...	
Password policies	DisablePasswordExpiration
Password profile	
Authorization info	View
Job Information	
Job title	Security Analyst
Company name	
Department	IT
Employee ID	EMP-2026-001
Employee type	
Employee hire date	May 29, 2026, 4:00 a.m.
Employee org data	
Office location	
Manager	Hazz Alhebshi
ZIP or postal code	
Country or region	
Business phone	
Mobile phone	
Email	joiner.test@simbaloa.onmicrosoft.com
Other emails	
Proxy addresses	View
Fax number	
IM addresses	View
Mail nickname	joiner.test
Parental controls	
Age group	
Consent provided for minor	
Legal age group classification	
Settings	
Account enabled	Yes
Usage location	Canada
Preferred data location	
On-premises	
On-premises sync enabled	Yes
On-premises last sync date time	May 28, 2026, 7:51 p.m.
On-premises distinguished name	CN=Joiner Test,OU=EntraID-Users,DC=Simbaloa,DC=local
Extension attributes	
On-premises immutable ID	KhK/UooxhEWYDczNVZ7Rw==

One lesson that cost me time: the value reached the metaverse fast but the export to Entra ID took much longer than the normal sync cycle. Verify each stage separately (AD, metaverse, Entra ID) before assuming you misconfigured something. Sometimes the answer is patience.

4. Identity Lifecycle (Joiner, Mover, Leaver)

JML is the heart of IAM. Least privilege, privilege creep, orphaned access, all of it comes down to how well this lifecycle is automated.

Joiner

A new hire needs the right access before day one: license, groups, a way to sign in, and a notified manager. I created the joiner in AD with full attributes (department, title, manager, employee ID) in the synced OU, set the hire date attribute, and built a Lifecycle Workflow from the Onboard pre-hire employee template. It triggers one day before the hire date, but only for users where department equals IT.

The workflow generates a Temporary Access Pass, adds the user to the IT staff group, assigns the M365 E5 license, and emails the manager. The TAP solves the bootstrap problem: a brand new user has no MFA method registered yet, but Conditional Access requires MFA. The TAP gets them in so they can register.

Joiner Lifecycle Workflow tasks summary

The screenshot shows the 'Onboard pre-hire employee' workflow in the Microsoft Entra ID console. The left sidebar contains navigation links: Overview, Manage (Properties, Tasks, Execution conditions, Version, Administration scope), and Activity (Workflow history). The 'Tasks' link is selected. The main area displays a table of tasks for the workflow. Above the table are controls: a back arrow, '+ Add task', 'Disable', 'Enable', 'Reorder', 'Remove', and 'Got feedback?'. A note states: 'Tasks can be added, modified, or reordered to define the set of actions for your custom workflows. [Learn more](#)'. The table has columns for 'Task order', 'Name', and 'Enabled'.

Task order	Name	Enabled
1	Assign licenses to user	Yes
2	Add user to groups to Intune only	Yes
3	Send Welcome email	Yes
4	Generate TAP and Send Email	Yes

Workflow history showing all tasks completed

Name	Run start date	Task status	Total users	Failed users	Unprocessed users
Generate TAP and Send Email	2026-05-31, 9:45 p.m.	Completed	1	0/1	0/1
Send Welcome email	2026-05-31, 9:45 p.m.	Completed	1	0/1	0/1
Add user to groups to Intune only	2026-05-31, 9:45 p.m.	Completed	1	0/1	0/1
Assign licenses to user	2026-05-31, 9:45 p.m.	Completed	1	0/1	0/1
Assign licenses to user	2026-05-28, 9:48 p.m.	Completed	1	0/1	0/1
Add user to groups to Intune only	2026-05-28, 9:48 p.m.	Completed	1	0/1	0/1
Send Welcome email	2026-05-28, 9:48 p.m.	Failed	1	1/1	0/1
Generate TAP and Send Email	2026-05-28, 9:48 p.m.	Completed	1	0/1	0/1
Assign licenses to user	2026-05-28, 9:43 p.m.	Canceled	1	0/1	1/1
Add user to groups to Intune only	2026-05-28, 9:43 p.m.	Canceled	1	0/1	1/1

The workflow scheduler runs about every three hours, so it does not fire instantly. For testing I used Run on demand, then let it fire on its own and kept the workflow history as proof it worked unattended.

Mover

The mover stage is the one most organizations get wrong. They grant the new role and forget to remove the old one, so people pile up access from every role they ever had. I made the department attribute the single control. Dynamic groups re-evaluate when it changes:

```
DYN-IT-Department: (user.department -eq "IT")
DYN-Finance-Department: (user.department -eq "Finance")
```

I changed the user's department in AD (never in the portal, since AD is the source of truth), ran a delta sync, and verified both directions: the user appeared in the IT group and disappeared from the Finance group. The second check is the one teams forget.

Leaver

I built the leaver flow twice on purpose, because there are two different questions to answer.

The first is planned offboarding. A Lifecycle Workflow from the Offboard an employee template triggers on the leave date and disables the account, revokes all sessions, removes group memberships, removes licenses, and notifies the manager. Each task leaves its own audit history.

The second is immediate containment. Disabling an AD account blocks new sign-ins but does not kill active tokens. Outlook and Teams sessions stay alive up to an hour unless someone revokes them. So I built a SOAR chain: a scheduled task on the DC disables the account on the termination date, Entra Connect syncs the disabled state, a Sentinel rule catches the AccountEnabled change in the audit logs, and a Logic App with a managed identity revokes sessions, strips licenses, and emails the manager within seconds. The same chain fires when an analyst disables an account during an incident, which is its real value.

Sentinel incident from the account-disable detection and the Logic App run history

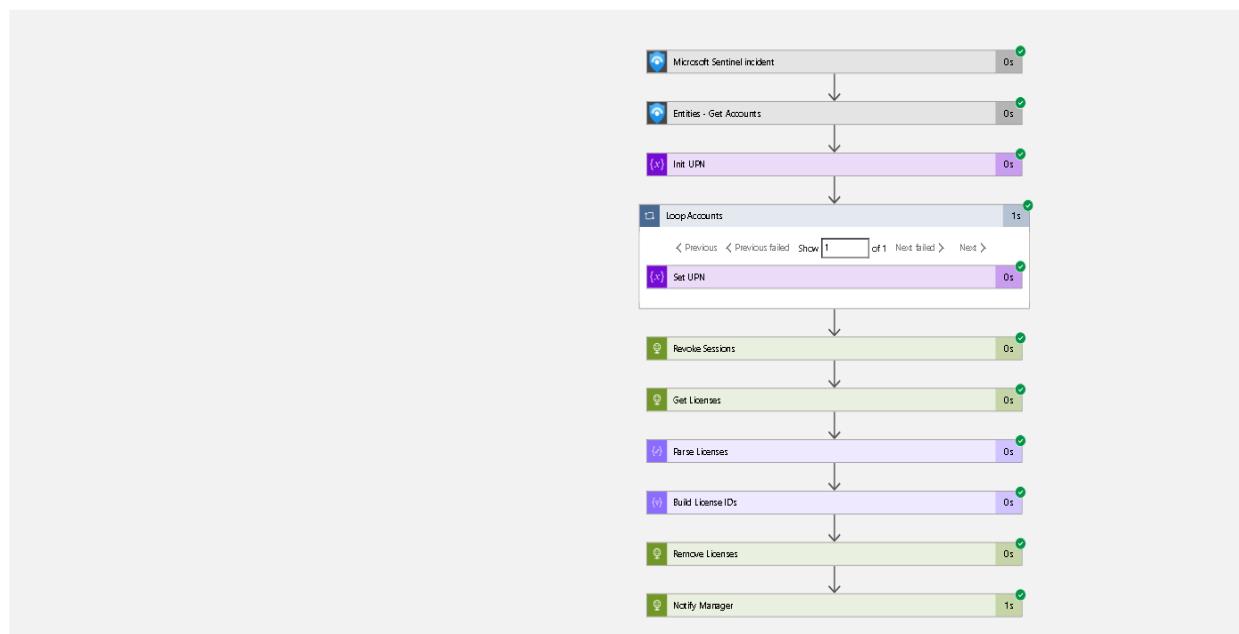
The screenshot shows the Microsoft Defender console interface. On the left is a navigation pane with options like Home, Exposure management, Investigation & response, Alerts, Hunting, Threat intelligence, and Assets. The main area displays an incident titled 'ID 12: Leaver-Account-Disabled-Detection' with a severity of 'High' and status 'Active'. Below the incident details, there's a section for 'Run playbook on incident' showing a table of runs. The table has columns for Name, Status, Start time, End time, and View run. It lists 9 items, all with a status of 'Failed'.

Name	Status	Start time	End time	View run
Is-leaver-containment91	Succeeded	Jun 11, 2026 1:00 AM	Jun 11, 2026 1:01 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 1:58 AM	Jun 11, 2026 1:59 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 2:55 AM	Jun 11, 2026 2:55 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 2:52 AM	Jun 11, 2026 2:52 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 2:46 AM	Jun 11, 2026 2:46 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 2:42 AM	Jun 11, 2026 2:43 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 2:41 AM	Jun 11, 2026 2:41 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 1:54 AM	Jun 11, 2026 1:54 AM	View run
Is-leaver-containment91	Failed	Jun 11, 2026 1:48 AM	Jun 11, 2026 1:48 AM	View run

Home

Logic app run
00584204456276411278166227641CU16

Run Details Resubmit Cancel run Refresh Info Generally Available Designer



5. Access Governance

Three RBAC systems, not one

Microsoft has three separate RBAC systems and mixing them up causes real over-privilege. Entra roles control the identity plane. Azure RBAC controls Azure resources. App roles control features inside one application. A Global Admin has zero access to Azure resources unless someone separately grants an Azure RBAC role. They are fully separate control planes.

To show scoped delegation I created an Administrative Unit with only standard users in it and assigned Password Administrator to a helpdesk account scoped to that AU. The helpdesk user can reset passwords for standard users but not for admins. I tested both outcomes.

Administrative Unit with Password Administrator assignment scoped to standard users

The screenshot shows the Microsoft Entra admin center interface. The left sidebar contains navigation links: Home, Security Copilot agents, Security Copilot chat, Favorites, Entra ID (expanded), Overview, Users, Groups, Devices, Agents, Enterprise apps, App registrations, and Roles & admins. The main content area is titled 'AU-StandardUsers | Properties' and includes a search bar, 'Save' and 'Discard' buttons, and a 'Manage' section with links to Properties, Users, Groups, Devices, and Roles and administrators. The 'Properties' section is active, showing the following details:

- Display name ***: AU-StandardUsers
- Description**: Standard user accounts only — no admins
- Membership type ***: Assigned
- Object ID**: 59c7d7b8-a39a-4b94-8f21-1f806592f4b1
- Restricted management administrative unit**: No

PIM

Nobody in my environment holds Global Admin permanently. The role is eligible through PIM with a two hour activation limit, justification required, MFA on activation, and approval from a second admin. I also kept two cloud-only break-glass accounts excluded from PIM and Conditional Access, because a PIM or CA misconfiguration that locks everyone out needs a recovery path.

PIM role settings for Global Administrator

The screenshot shows the 'Global Administrator | Role settings' page in the PIM console. The left sidebar has links for Assignments, Description, and Role settings. The main content area is divided into two sections: 'Activation' and 'Assignment', each with a table of settings.

Setting	State
Activation maximum duration (hours)	2 hour(s)
On activation, require	Azure MFA
Require justification on activation	Yes
Require ticket information on activation	Yes
Require approval to activate	Yes
Approvers	1 Member(s), 0 Group(s)

Setting	State
Allow permanent eligible assignment	Yes
Expire eligible assignments after	-
Allow permanent active assignment	No
Expire active assignments after	15 day(s)
Require Azure Multi-Factor Authentication on active assignment	No
Require justification on active assignment	Yes

Send notifications when members are assigned or affected to this role.

Access packages and access reviews

I built an access package bundling the groups an IT security analyst needs, with manager approval, 365 day expiry, and an auto-assignment policy on the department attribute. When the department no longer matches, access is removed automatically. That auto-remove is what closes the mover gap at the governance layer.

For reviews I set up a monthly review of privileged role holders and a quarterly review of guest accounts. The guest review is fail-secure: if the reviewer does not respond, access is removed, not kept. I also turned on the guest lifecycle setting under ID Governance so external accounts get blocked and removed after their access expires.

IT-Security-Analyst-Access Access package

The screenshot shows the 'IT-Security-Analyst-Access' access package page. The left sidebar contains navigation links: Overview, Manage, Resource roles, Policies, Separation of Duties, Assignments, Requests, and Access reviews. The main content area displays the package name and description: 'Access for IT Security Analysts — Sentinel read, security groups'. Below this, the 'Properties' section shows details like 'Created by: Hussein@Simbalooa.onmicrosoft.com', 'Created on: 2026-05-26', 'Object Id: 7dfa84e2-b961-4cc0-85be-eef8229431ce', and 'My Access portal link: https://myaccess.microsoft.com/@Simbalooa.onmicro...'. The 'Contents' section shows 'Resource roles' (2 Groups and Teams, 0 Apps, 0 SPO, 0 Microsoft Entra role, 0 OAuthApplication) and 'Policies' (1 Enabled, 0 Disabled). The 'Activity' section shows '1 Assignments', '0 Pending Requests', and 'N/A Change Propagation Sync'.

Auto Assignment policy in access package

The screenshot shows the 'IT-Security-Analyst-Access | Policies' page. The left sidebar contains navigation links: Overview, Manage, Resource roles, Policies, Separation of Duties, Assignments, Requests, and Access reviews. The main content area displays a table of policies. The table has columns: Name, Description, Active assignment..., and Enabled. The policies listed are 'Auto Assignment IT Department' and 'Initial Policy'. Below the table, the 'Policy details' section shows details for the 'Auto Assignment IT Department' policy, including its description, Policy ID, Assignments created for, and various settings like 'Automatically create assignments' and 'Automatically remove assignments'.

Name	Description	Active assignment...	Enabled
☐ Auto Assignment IT Department	Automatically assigns access to users in the IT department and removes access w...	0	Always enabled
☐ Initial Policy	Initial Policy	1	Yes

Policy details	
Name	Auto Assignment IT Department
Description	Automatically assigns access to users in the IT department and removes access when department changes
Policy ID	25a38990-c892-4f53-bfd6-9fcfa6fde312
Assignments created for	All users matching filter (user.department -eq "IT")
Automatically create assignments	Yes
Automatically remove assignments	Yes

Segregation of Duties

SoD prevents one person from holding a toxic combination of access, the classic case being someone who can create a payment and also approve it. In Entra I enforced this with incompatible access packages: holding the vendor-create package blocks requesting the payment-approve package. Entra covers Microsoft-resident access only. Real cross-application SoD, like an SAP role conflicting with an Oracle role, needs an IGA platform, and I cover that in section 8.

Home > Identity Governance | Access packages > IT-Security-Analyst-Access | Policies > Identity Governance | Access reviews > Review01 | Overview > Identity Governance

AP-Payment-Approve | Separation of Duties

Access package

« + Add access package + Add group

Overview

Manage

- Resource roles
- Policies
- Separation of Duties**
- Assignments
- Requests
- Access reviews

Incompatible access packages		Incompatible groups	Incompatible With
Name	Object Id		
AP-Vendor-Create	2f73a3ee-246f-4f9e-9adb-f8568af6c386		

6. Authentication and Zero Trust

Governance decides what access exists. Authentication checks at every sign-in that the right person is using it. My Conditional Access baseline:

- Require MFA for all users (break-glass excluded)
- Block legacy authentication completely
- Require a compliant or hybrid-joined device for M365 apps
- Require phishing-resistant MFA for admin roles

Everything was staged in report-only mode first.

Conditional Access policy list

Home > Authentication methods | Authentication strengths > Conditional Access

Conditional Access | Policies

Microsoft Entra ID

Overview Policies Deleted Policies Phased rollout Insights and reporting Diagnose and solve problems

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication contexts
- Authentication strengths
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting + Support

- New support request

+ New policy + New policy from template ↑ Upload policy file 👤 What if ↻ Refresh 🛠 Preview features

Microsoft Entra Conditional Access policies are used to apply access controls to keep your organization secure. [Learn more](#)

**Microsoft-managed policies**
Policies created ⓘ
0

**User created policies**
Policies created ⓘ
10

🔍 Search policies **Add filter**

10 out of 10 policies found

Policy name	Created by	State	AI
CA001-MFA-ALLUSERS-ALLAPPS	USER	Report-only	
CA002-PhishResistantMFA-AdminRoles	USER	Report-only	
CA003-CompliantDevice-M365Apps	USER	Report-only	
CA004-Block-LegacyAuth-AllUsers	USER	Report-only	
CA005-Block-HighRiskSignIn	USER	Report-only	
CA006-LimitSession-UnmanagedDevices	USER	Report-only	
CA007-blockcountries	USER	Report-only	
Require MDM-enrolled and compliant device to access d...	USER	Report-only	
Require multifactor authentication for risky sign-ins	USER	Report-only	
Require password change for high-risk users	USER	Report-only	

The phishing-resistant part matters because standard push MFA can be beaten. An adversary-in-the-middle proxy like Evilginx relays the real MFA prompt and steals the resulting token. MFA happened, and the attacker still got in. FIDO2 and Windows Hello for Business are bound to the device and cannot be relayed that way. I built an Authentication Strength allowing only those two methods and attached it to the admin Conditional Access policy. I also enabled Token Protection in report-only and Continuous Access Evaluation, and tested that revoking a session kicks the user out of Outlook within about a minute instead of up to an hour.

Custom Authentication Strength

The screenshot displays the Microsoft Entra ID Security console. On the left, a navigation pane shows 'Authentication strengths' selected under the 'Manage' section. The main area is titled 'Authentication methods | Authentication strengths'. It includes a search bar, a '+ New authentication strength' button, and a 'Refresh' button. Below this, a table lists authentication strengths:

Authentication strength	Type	Authentication methods
IT-Staff-Strong-Auth	Custom	Windows Hello For Business / Platform Credential and 3 more
Multifactor authentication	Built-in	Windows Hello For Business / Platform Credential and 16 more
Passwordless MFA	Built-in	Windows Hello For Business / Platform Credential and 3 more
Phishing-resistant MFA	Built-in	Windows Hello For Business / Platform Credential and 2 more

On the right, a 'View Authentication Strength' pane is open for 'Phishing-resistant MFA'. It shows the name, type (Built-in), and description. Below, it lists authentication flows: 'Windows Hello For Business / Platform Credential', 'OR', 'Passkeys (FIDO2)', 'OR', and 'Certificate-based Authentication (Multifactor)'.

SSO and SCIM

SCIM automatic provisioning requires a paid tier on most SaaS apps including Salesforce and Slack. I configured SAML SSO to Salesforce with Entra as the identity provider but could not validate full SCIM provisioning end to end. The pattern is the same across gallery apps set provisioning mode to Automatic, provide the tenant URL and token, map attributes, and Entra handles the rest. This section is conceptual

App registrations and OAuth

I built an app registration with delegated and application Graph permissions to understand both sides of the consent model, then did the defensive half: reviewing third party enterprise apps for dangerous grants like Mail.ReadWrite or Directory.ReadWrite.All at the application level. Illicit consent attacks give an attacker standing access with no stolen password and nothing for MFA to catch, so knowing how to find and revoke these grants matters.

7. Identity Threat Detection and Response

Prevention fails eventually, so this part assumes breach and focuses on detecting attacks against the identity plane itself.

Defender for Identity and AD attacks

I activated the MDI sensor on the domain controller, tagged the admin accounts as sensitive, and planted a honeypot: a deliberately unused account where any authentication means an attacker is inside. Then I simulated three attacks against my own domain and confirmed MDI caught each one:

- Kerberoasting: requested a Kerberos ticket for a service account SPN. MDI flagged the suspicious ticket request.
- LDAP reconnaissance: enumerated users and Domain Admins membership. MDI flagged directory recon.
- DCSync: simulated replication of password hashes, the attack that exposes the krbtgt hash and enables Golden Tickets.

MDI honeypot alert (Incident 13) and IdentityQueryEvents showing LDAP recon captured

The screenshot displays the Microsoft Defender for Identity console interface. At the top, the breadcrumb navigation shows 'Incidents > Honeytoken authentication activity involving one user'. The main heading is 'ID 13: Honeytoken authentication activity involving one user'. Below this, there are status indicators: 'Medium' (yellow square), 'Active' (blue circle), 'Unassigned' (person icon), 'Unclassified' (pencil icon), and 'Last update time: Jun 11, 2026 6:44 PM'. A horizontal menu bar includes 'Attack story' (selected), 'Alerts (1)', 'Activities (1)', 'Assets (1)', 'Investigations (0)', 'Evidence and Response (2)', and 'Summary'. Below the menu bar, there are filter buttons: 'Severity: Any', 'Status: Any', 'Service sources: Any', and 'Add filter'. The main content area is divided into two panels. The left panel, titled 'Detection & Categories', shows 'Active alerts: 1/1', 'Categories: 1', 'First activity: Jun 11, 2026 6:41:28 PM', 'Last activity: Jun 11, 2026 6:41:28 PM', 'Creation time: Jun 11, 2026 6:44:32 PM', and an 'Alerts' section with one alert: 'Jun 11, 2026 6:41 PM New Honeytoken authentication activity IT Admin Old'. The right panel, titled 'Incident graph', shows a network diagram with nodes for 'SIMBA-DC01' and 'it.admin.olc'. The graph is currently empty, showing only the background grid.

Identity Protection

Sign-in risk at medium or above requires MFA. High user risk requires a secure password change. These two policies handle the bulk of standard users automatically, with no analyst involved.

Sentinel and automated containment

All identity signals land in Sentinel: DC security events, Entra sign-in and audit logs, MDI alerts, and Identity Protection risk events. I wrote KQL detections for privileged group changes, honeytoken authentication, and risky sign-ins correlated against admin role membership.

The last one feeds a SOAR playbook. The scoping decision matters here: the rule targets user risk joined to admin role membership, so it only fires for privileged accounts. When it fires, a Logic App revokes the account's sessions, disables it, and alerts the SOC. I deliberately did not aim this at standard users, because auto-disabling every risky user would override the gentler self-service remediation and cause mass lockouts. Privileged accounts get contained, standard users get a password change prompt.

8. Network Identity Controls

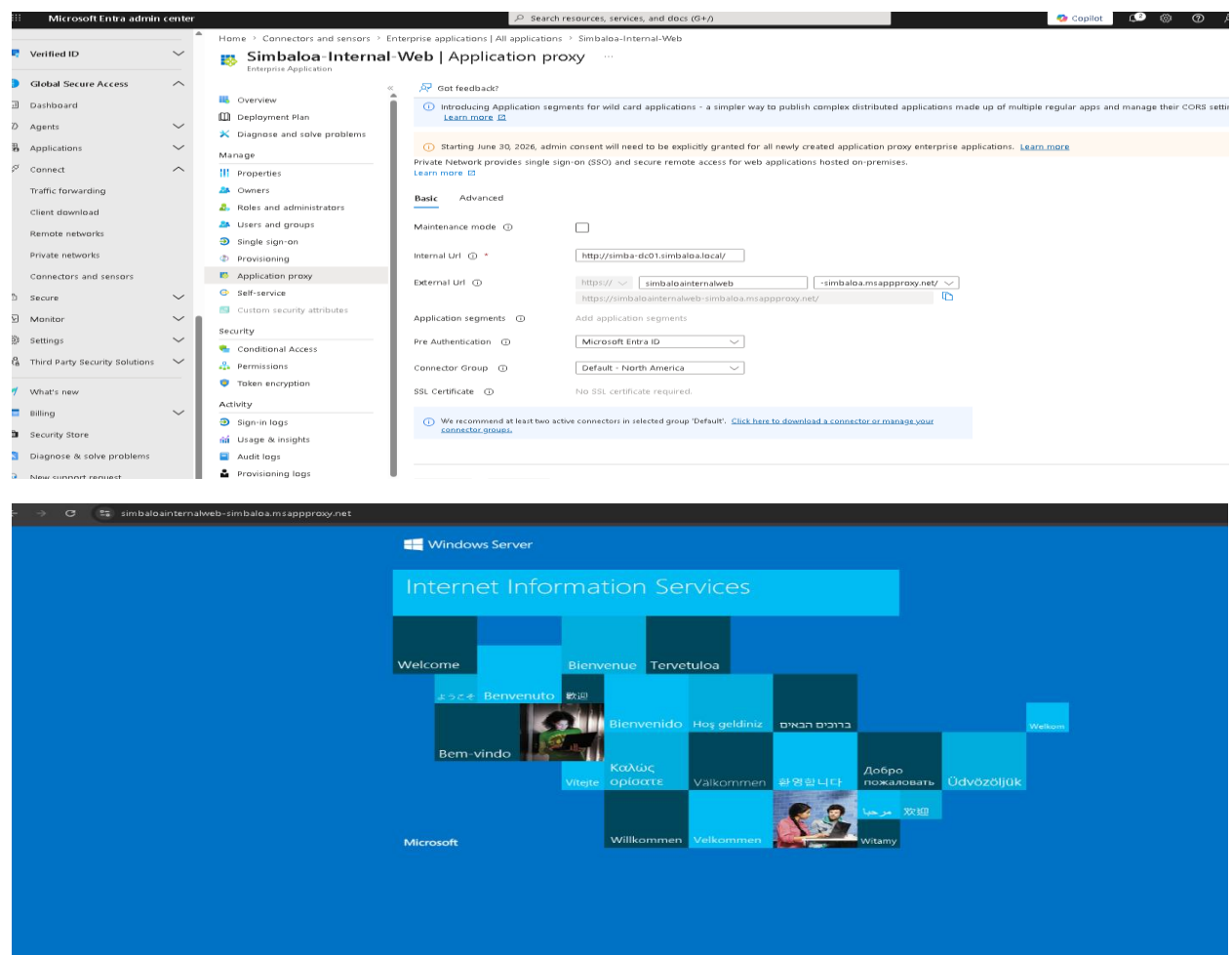
Identity controls do not stop at the directory. Three additional controls extend Zero Trust to how resources are accessed over the network.

Application Proxy

Application Proxy lets you publish an internal on-premises web application to the internet through Entra ID without opening firewall ports. The connector is a lightweight agent installed on a domain-joined server inside your network. When a user accesses the external URL the request goes through Entra ID first, meaning all your Conditional Access policies and MFA requirements apply before the user ever reaches the internal resource.

I installed the Microsoft Entra private network connector on the domain controller, published the internal IIS site as an enterprise application, and verified that the external msapproxy.net URL redirected to Entra sign-in and then served the internal page. Pre-authentication is set to Microsoft Entra ID so no request reaches the backend without a valid token.

One production consideration: Microsoft recommends installing the connector on a dedicated member server rather than a domain controller to reduce the DC attack surface. In a lab one machine works fine.



Home

>

Connectors and sensors

>

Enterprise applications

>

All applications

>

Simbaloa-Internal-Web

>

Application proxy

Users | Sign-in logs

hebshi

Download

Export Data Settings

Troubleshoot

Refresh

This view will soon be replaced with a view that includes more filters infinite scrolling, a

Date : Last 24 hours

Show dates as : Local

Add filters

User sign-ins (Interactive)

User sign-ins (non-interactive)

User	Application
ec7-4bb... Hussein	Azure AD Application Proxy Connector
i7b-4eb3... Hussein	Azure Portal

Activity Details: Sign-ins

REQUEST ID

72249320-92E7-400D-9002-E0D000001400

Correlation ID

5cd632a2-3d7-44ff-9b15-dd3f948cd556

Authentication requirement

Single-factor authentication

Agent Type

Not Agentic

Status

Success

Continuous access evaluation

No

Follow these steps:

Launch the Sign-in Diagnostic

1. Review the diagnosis and act on suggested fixes.

Troubleshoot Event

User

Hussein

Username

hussein@simbaloa.onmicrosoft.com

User ID

49cb20a9-5c6e-4138-9b2c-be59a0164c9d

Sign-in identifier

hussein@simbaloa.onmicrosoft.com

Session ID

005d1c0a-54d8-a58c-d89f-3affb2c85104

App owner tenant ID

f8cdef31-a31e-4b4a-93e4-5f571e91255a

Resource owner tenant ID

f8cdef31-a31e-4b4a-93e4-5f571e91255a

User type

Member

Cross tenant access type

None

Application

Azure AD Application Proxy Connector

Application ID

55747057-9b5d-4bd4-b387-abf52a8bd489

Resource

Azure AD Application Proxy

Resource ID

47ee738b-3f1a-4fc7-ab11-37e4822b007e

Resource tenant ID

f8b88c8a-0e28-4b43-8dfd-e0ee8e8428e9

Home tenant ID

f8b88c8a-0e28-4b43-8dfd-e0ee8e8428e9

Home tenant name

Client app

Minihile Apps and Desktop clients

Entra Private Access

Entra Private Access is Microsoft's Zero Trust Network Access solution, part of Global Secure Access. Instead of a traditional VPN that grants broad network access, Private Access lets you define specific internal resources by IP, FQDN, or port and only those resources are tunneled. Every connection goes through Microsoft's network with identity-based access controls applied.

The same private network connector used by Application Proxy handles Private Access too. I configured a Quick Access app in Global Secure Access pointing to my DC's internal IP on port 80, enabled the Private Access traffic forwarding profile, and installed the Global Secure Access client on my hybrid-joined endpoint. With the client running the endpoint reaches the internal resource without a VPN.

The key difference from Application Proxy: Application Proxy publishes specific web apps externally. Private Access replaces VPN with granular, identity-aware network access to any resource type.

Home > Traffic forwarding > Client download

Quick Access | Network access properties

Manage

Network access properties

Users and groups

Security

Conditional Access

Troubleshooting + Support

New support request

«

Edit application settings

Got feedback?

Global Secure Access is now generally available. Licensing requirements have been updated. [Learn more](#)

Name

Quick Access

Connector Group

Default - North America

We recommend at least two active connectors in selected group 'Default'. [Click here to download a connector or manage your connector groups.](#)

Application segment

Private DNS

Service principal name

+ Add Quick Access application segment

Destination type	Destination	Ports	Protocol	Status	Delete
IP address	192.168.100.30	80	TCP	Success	

- Home
- Security Copilot agents
- Security Copilot chat
- Favorites
- Entra ID
- Overview
- Users
- Groups
- Devices
- Agents
- Enterprise apps
- App registrations
- Roles & admins
- Delegated admin partners
- Tenant governance (Preview)
- Domain services
- Conditional Access
- Multifactor authentication
- Identity Secure Score
- Authentication methods

Home

Traffic forwarding

Refresh

Got feedback?

Manage traffic forwarding profiles

Traffic forwarding profiles enable admins to forward specific traffic to Global Secure Access. Assign traffic forwarding profiles to users running the Global Secure Access client. For clientless devices, use the Microsoft profile to assign to remote networks. [Learn more](#)

One or more profiles are configured and ready to use. To finish setup, Download [Global Secure Access client](#).

Microsoft traffic profile

Disabled

Last modified on 06/10/2026, 07:12 PM

Applies to

Internet traffic to Microsoft services

Microsoft traffic policies

4 policies [View](#)

Linked Conditional Access policies

8 policies [View](#)

User and group assignments

0 users, 0 groups assigned [View](#)

Remote network assignments

0 assigned remote networks [View](#)

Private access profile

Enabled

Last modified on 06/10/2026, 07:46 PM

Applies to

Private resources

Private access policies

Quick Access, 0 Applications

Linked Conditional Access policies

None

User and group assignments

All users assigned [View](#)

Remote network assignments

Not applicable

Internet access profile

Disabled

Last modified on not available

Applies to

All internet traffic, except for the Microsoft traffic profile

Internet access policies

5 policies [View](#)

Linked Conditional Access policies

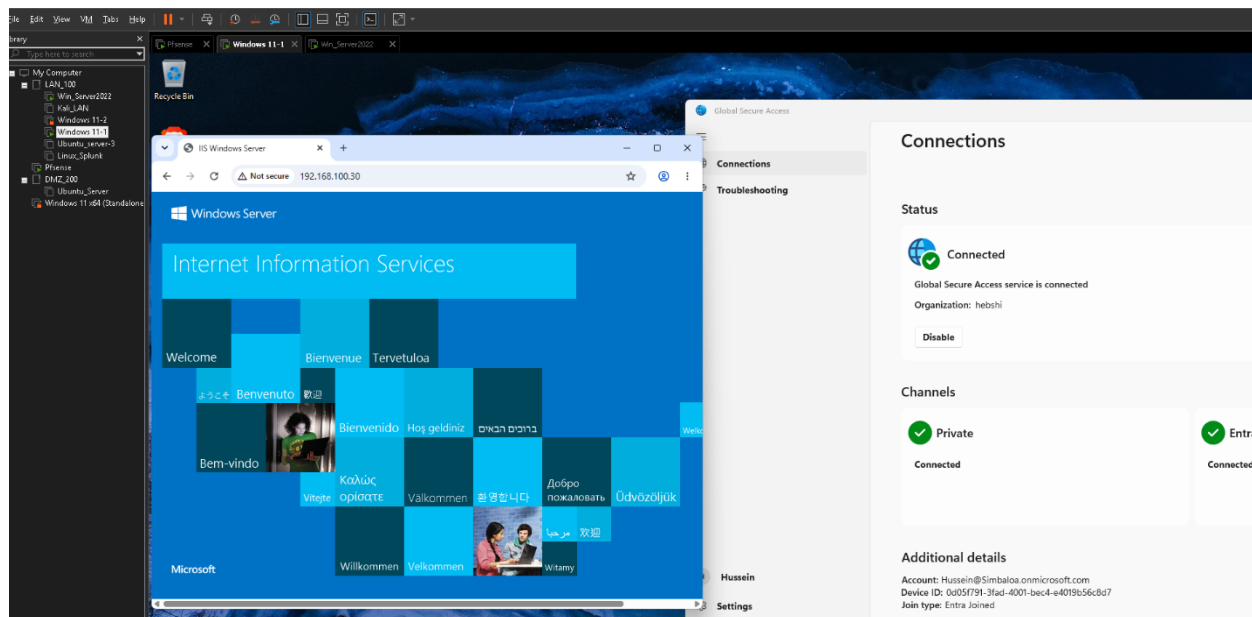
8 policies [View](#)

User and group assignments

0 users, 0 groups assigned [View](#)

Remote network assignments

0 assigned remote networks [View](#)

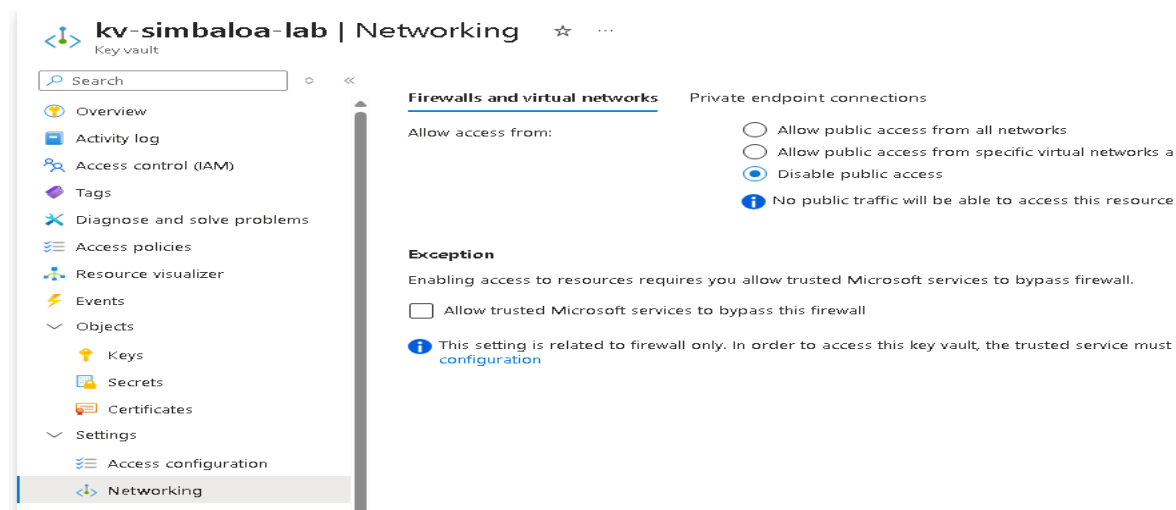


Private Endpoints

A private endpoint gives an Azure resource a private IP address inside your VNet so traffic to it never leaves the Microsoft backbone and never touches the public internet. Without a private endpoint, services like Key Vault are reachable over their public endpoint by default.

I created a Key Vault with public access disabled, deployed a private endpoint connecting it to a dedicated subnet, and let Azure create the private DNS zone automatically. The zone maps the Key Vault hostname to its private IP so name resolution works correctly inside the VNet. The result is a Key Vault that is completely unreachable from the public internet but accessible from anything inside the VNet.

This matters for the IAM story because Key Vault stores the secrets and certificates used by app registrations, managed identities, and automation. Putting it behind a private endpoint means those credentials are only reachable from trusted network paths.



kv-simbaloa-lab | Networking

Key vault

Search

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Access policies

Resource visualizer

Events

Objects

Keys

Secrets

Certificates

Settings

Access configuration

Networking

Microsoft Defender for Cloud

Properties

Locks

Firewalls and virtual networks

Private endpoint connections

Private endpoints allow access to this resource using a private IP address from a virtual network, effectively bringing the service into your virtual network. [Learn more about private endpoint connections](#)

Create

Refresh

Approve

Reject

Remove

Filter by name...

Connection states == All

Private endpoint	Connection name	Sub-resource	Subnet	Connection state	Description
☐	pe-keyvault-lab	vault	VNet-Lab/subnet-private	Approved	

Home > Key vaults > kv-simbaloa-lab | Networking > pe-keyvault-lab

pe-keyvault-lab | DNS configuration

Private endpoint

Search

Add configuration

Refresh

Overview

Activity log

Access control (IAM)

Tags

Diagnose and solve problems

Resource visualizer

Settings

Application security groups

DNS configuration

Properties

Locks

Monitoring

Insights

Alerts

Metrics

Automation

CLI / PS

Tasks

Export template

Help

Private DNS integration

To connect privately with your private endpoint, you need a DNS record. We recommend that you integrate your private endpoint using a private DNS zone. You can also utilize your own DNS servers. [Learn more](#)

Customer Visible FQDNs

DNS records visible to the customer

Network Interface	IP addresses	FQDN
pe-keyvault-lab-nic	10.0.14	kv-simbaloa-lab.vault.azure.net

Configuration name	FQDN	IP address	Subscription	Private DNS zone	DNS zone group
privatelink-vaultcore-azure...			Azure subscription 2	privatelink.vaultcore.azure.net	default
	kv-simbaloa-lab.privatelink.vaultcore.azure.net			-	-
		10.0.14		-	-

9. Enterprise IGA and PAM

Entra governs identities inside the Microsoft estate and SCIM-connected apps. Enterprises run hundreds of other systems, and the entitlements that matter most for fraud usually live in SAP and Oracle. That is what dedicated IGA platforms exist for.

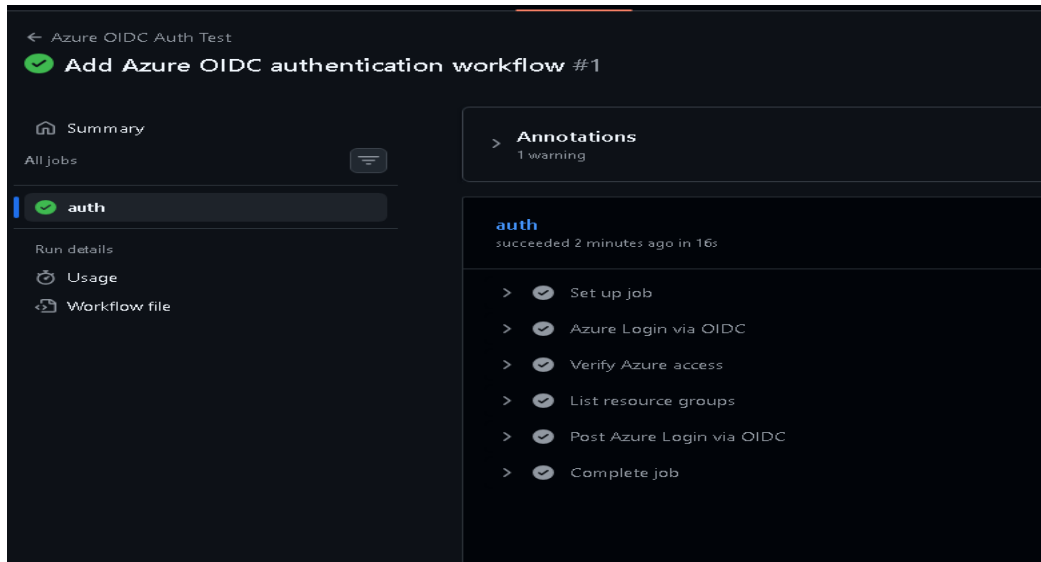
SailPoint

SailPoint Identity Security Cloud is a dedicated IGA platform that aggregates identities from hundreds of source systems including SAP, Oracle, Salesforce, and mainframes into one governance model. Unlike Entra which governs the Microsoft estate only, SailPoint runs certification campaigns, mines roles, and enforces SoD policies across every connected system. A hands-on tenant requires either a customer license or SailPoint partner status — no self-service developer tenant is available without reaching 400 ambassador points in the SailPoint developer community. I have joined the community and am working toward ambassador status to get hands-on access. The cross-application SoD scenario (SAP vendor-

create conflicting with Oracle payment-approve) is the capability Entra cannot provide and the main reason regulated enterprises buy a dedicated IGA platform.

Workload identity federation

CI/CD pipelines used to need stored client secrets, which leak and expire. I set up federated credentials on an app registration so GitHub Actions authenticates to Azure with an OIDC token instead. The repo holds only IDs, no secrets. Nothing to rotate, nothing to leak.



PAM concepts

CyberArk needs an enterprise license I do not have, so this part is conceptual and I am saying so directly. The short version of the mapping: PIM gives just-in-time elevation for Entra and Azure roles. CyberArk extends that idea to everything else, with credential vaulting where no human knows the password, full session recording, and automatic rotation after every use. Mature organizations run both: PIM governs the cloud identity plane and the PAM platform governs servers, databases, and network gear.

10. Problems I Hit Along the Way

- Three AD attributes failed for the lifecycle date mapping before msDS-cloudExtensionAttribute worked. The failures taught me more about the Entra Connect schema than the success did.
- A plain date string fails the sync. The Generalized-Time format requirement is barely documented and the error message does not tell you what format it wants.
- A cloned sync rule at the wrong precedence can break attribute flow for every synced user. I disabled my bad clone and kept it as evidence instead of deleting it.
- Disabling an account does not end its sessions. Every leaver path I built revokes sessions explicitly, and Continuous Access Evaluation is what makes that near-instant.
- The lifecycle workflow scheduler is not instant. It evaluates roughly every three hours, which is fine in production and confusing in a lab if you do not know it.